

Zero Trust Architecture for Enterprise Security

AWS-based implementation with MFA, RBAC, micro-segmentation and encryption

Minor Project 2 - Internship Submission

Submitted by: Sakshi Sharma

September 2026

1. Introduction and Objectives

Traditional enterprise security relies on a trusted internal network and a strong perimeter. Once an attacker or a malicious insider is inside, lateral movement is often easy. Zero Trust replaces implicit trust with continuous verification: every request must be authenticated, authorised, and logged, regardless of where it originates.

This project designs and implements a small Zero Trust environment on AWS and validates it with an insider-threat simulation. Objectives:

- Explain Zero Trust principles and how MFA and RBAC support them.
- Design a framework covering identity verification, micro-segmentation and encryption.
- Implement the identity and data-protection layers on AWS using least-privilege IAM policies, MFA and KMS.
- Test with a simulated insider threat, review the audit trail in CloudTrail, and report results and recommendations.

2. Zero Trust Principles

Zero Trust is summarised by the phrase **never trust, always verify**. Its core principles are:

Principle	Meaning	Applied in this project
Verify explicitly	Authenticate and authorise every request using all available signals.	IAM identity plus mandatory MFA on every user.
Least privilege	Grant only the access needed for the role, nothing more.	Custom JSON policies per role with explicit denies.
Assume breach	Design as if an attacker is already inside; limit blast radius.	Role separation, guardrail denies, segmented network design.
Micro-segmentation	Split the network into small zones with controlled flows.	VPC public/private subnets and Security Groups (design).
Encrypt everything	Protect data at rest and in transit.	KMS customer-managed key on S3 (SSE-KMS).
Continuous monitoring	Log and review all activity.	CloudTrail event history reviewed for denied actions.

3. MFA and RBAC

3.1 Multi-Factor Authentication (MFA)

A password alone is a single point of failure. MFA adds a second factor (a time-based one-time code from an authenticator app), so a stolen password is not enough to sign in. In this project every IAM user has a virtual MFA device, and a policy (*ZT-Enforce-MFA*) applies an explicit Deny to every action except the ones needed to set up MFA whenever the request was not authenticated with MFA.

3.2 Role-Based Access Control (RBAC)

RBAC assigns permissions to roles instead of individuals. Three roles were defined, each mapped to an IAM group and one custom policy:

User	Group	Policy	Summary
employee1	ZT-Employees	ZT-Employee	Read-only on public/ and employee/ data; no writes, no IAM, no EC2 control.
manager1	ZT-Managers	ZT-Manager	Read/write team data, start/stop only lab-tagged EC2, view audit logs.
admin1	ZT-Admins	ZT-Admin	Lab administration with guardrails: cannot stop CloudTrail or delete KMS keys.

All three groups also carry *ZT-Enforce-MFA*. The full permission matrix follows.

Resource/Action	employee1	manager1	admin1
S3 read public/*	Allow	Allow	Allow
S3 read employee/*	Allow	Allow	Allow
S3 read/write manager/*	Deny	Allow	Allow
S3 upload employee/*	Deny	Allow	Allow
S3 delete objects/bucket	Deny	Deny	Allow
KMS decrypt data key	Allow	Allow	Allow
KMS encrypt/generate data key	Deny	Allow	Allow
KMS disable/delete key	Deny	Deny	Deny
EC2 describe	Allow	Allow	Allow
EC2 start/stop/reboot	Deny	Allow (tagged only)	Allow
EC2 terminate	Deny	Deny	Allow
IAM any action	Deny	Deny	Allow
CloudTrail LookupEvents	Deny	Allow	Allow
CloudTrail stop/delete	Deny	Deny	Deny
Disable public access block	Deny	Deny	Deny (without MFA)
Any action without MFA	Deny	Deny	Deny

4. Framework Design

4.1 Identity verification

- Individual IAM identities for each person; no shared accounts.
- MFA enforced by policy, not by convention.
- Role-based groups so that access changes are made in one place.

4.2 Micro-segmentation

The target network design uses a VPC (10.0.0.0/16) with a public subnet for the jump host and a private subnet for internal workloads. Two Security Groups form the segments: a public group that allows RDP (TCP 3389) only from a single allow-listed /32 address, and a private group that accepts RDP only from the public group. Traffic between segments is therefore explicit, and no workload is

exposed to the internet by default.

4.3 Encryption

Data at rest is protected with a customer-managed AWS KMS key. The S3 bucket uses SSE-KMS as its default encryption, so reading an object requires both S3 permission and permission to use the key. This creates a second control point: an identity with S3 access but no KMS permission cannot read the data. Data in transit uses HTTPS for S3 and console access.

4.4 Monitoring

AWS CloudTrail records API activity. Denied requests are retained with the user name, action and error code, giving evidence for audit and incident response.

5. AWS Implementation

Component	Configuration
Region	ap-south-1 (Mumbai)
Identity	3 IAM users (employee1, manager1, admin1) in 3 groups; virtual MFA on each user
Policies	ZT-Enforce-MFA, ZT-Employee, ZT-Manager, ZT-Admin (custom JSON, in repository /policies)
Data	S3 bucket with public/, employee/, manager/ prefixes; SSE-KMS with customer-managed key
Compute	Windows Server EC2 instance tagged Project=zero-trust-lab (used in the manager policy tag condition)
Network	VPC, public/private subnets and Security Group RDP allow-list as described in section 4.2
Automation	setup_iam.ps1 (AWS CLI) creates policies, groups and users

5.1 Policy design highlights

- **Prefix-scoped S3 access:** ListBucket is limited with an s3:prefix condition so each role only sees its own folders.
- **Explicit denies:** sensitive actions (IAM, CloudTrail, key deletion, EC2 termination) are denied even if another policy allows them; an explicit Deny always wins.
- **Tag-based EC2 control:** manager1 can start/stop only instances tagged Project=zero-trust-lab.
- **Admin guardrails:** admin1 cannot stop or modify CloudTrail, schedule key deletion, or change S3 public-access settings without MFA.
- **Optional IP allow-list:** a Deny-if-not-from-IP policy (04-ip-allowlist-deny.json) is provided for stricter access.

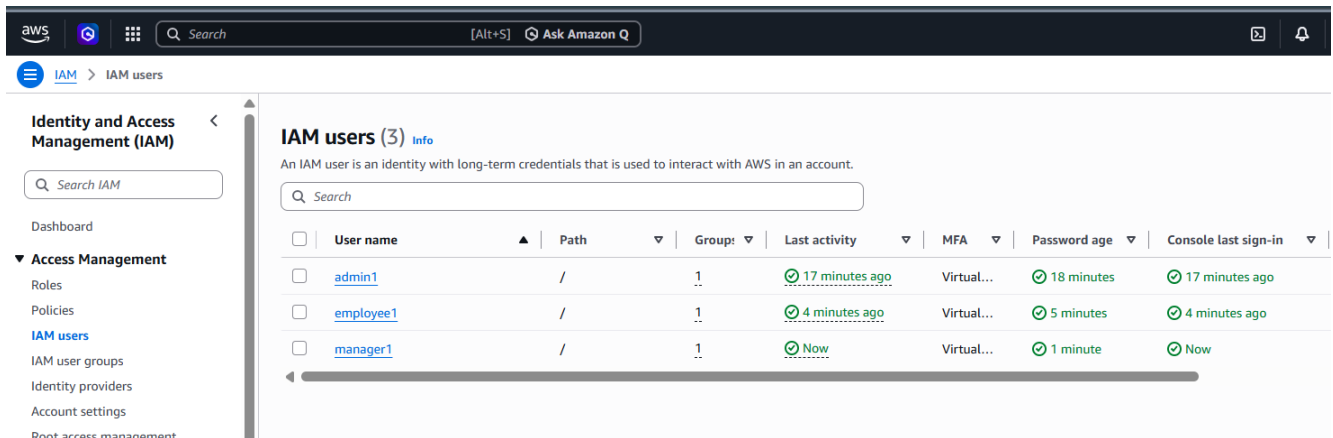


Figure 1: IAM users with virtual MFA enabled.

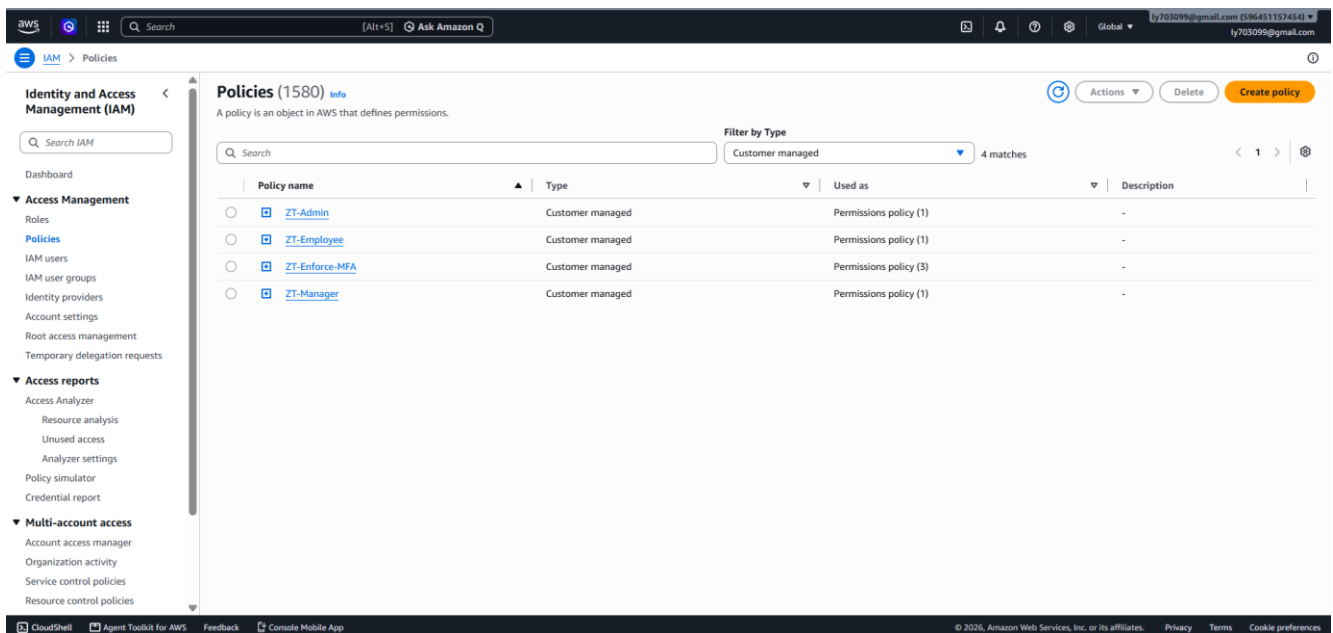


Figure 2: Group with least-privilege and MFA-enforcement policies attached.

6. Testing

6.1 Insider threat simulation

Scenario: a low-privilege employee attempts actions outside the role. employee1 signed in to the console with MFA and attempted a restricted action. Expected result: the request is rejected by IAM and recorded in CloudTrail.

6.2 External threat simulation

Scenario: an attacker tries to reach the Windows VM over RDP from an address that is not allow-listed. Design expectation: the Security Group drops the connection before it reaches the operating system. This live test was not executed in this lab (see Limitations), so the result is a design expectation rather than a measured outcome.

6.3 Test summary

#	Test	Expected	Status
1	Sign-in as IAM user with MFA	MFA code required at login	Observed
2	employee1 attempts restricted action	Access Denied	Observed (Figure 4)
#	Test	Expected	Status
3	CloudTrail review of denied activity	Denied event logged with user and error code	Observed (Figure 5)
4	RDP from non-allow-listed IP	Connection blocked by Security Group	Not executed (design only)

7. Results

The identity and data-protection layers behaved as designed. MFA was required for sign-in, the employee role was prevented from performing a restricted action, and the denial was visible in the audit trail with the acting user and error code. Because permissions are attached to groups, changing a person's access only requires a group change, and explicit denies keep sensitive actions out of reach even if a broader allow is added later.

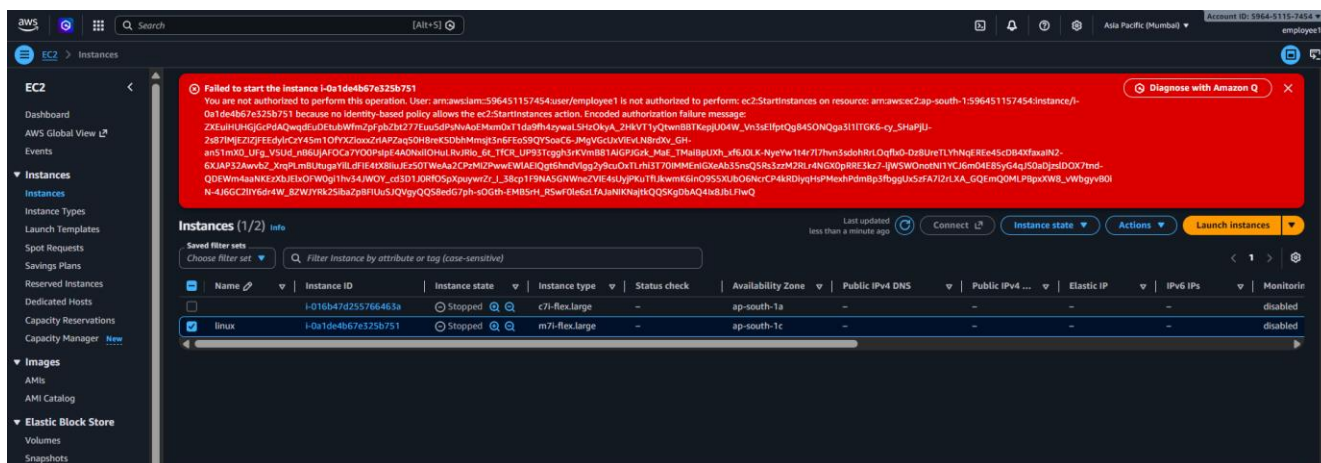


Figure 4: employee1 receives Access Denied on a restricted action.

8. Limitations

- The lab is small (three users, one bucket, one VM) and is not a full enterprise deployment.
- The external RDP test and full VPC segmentation were not validated live; they are presented as design.
- MFA uses virtual authenticator apps; hardware keys or phishing-resistant methods would be stronger.
- Long-lived IAM users were used for the lab; production should prefer federated access and temporary credentials.

9. Recommendations

- Enforce MFA on every identity, including the root account, and prefer phishing-resistant factors.
- Use IAM Identity Center or federation with short-lived credentials instead of IAM users.
- Replace public RDP with AWS Systems Manager Session Manager or a VPN.
- Alert on CloudTrail denied events using CloudWatch and SNS; enable GuardDuty.
- Review permissions regularly with IAM Access Analyzer and remove unused access.
- Apply the same segmentation and encryption pattern (private subnets, KMS, VPC endpoints) to production workloads.

Conclusion

Zero Trust is a set of layered controls rather than a single product. On AWS, strong identity (MFA + RBAC), least-privilege policies, segmentation and encryption can be combined with modest effort, and the audit trail provides the visibility needed to verify that the controls work.

